

MUNI

PV210 Cybersecurity Team and Its Services

Course organization and motivation

September 16, 2026

Jan Vykopal, Pavel Čeleda, Martin Laštovička

Course organization

Instructors – CYBERSEC and CSIRT-MU

Jan Vykopal

founder of the incident response team at MU (CSIRT-MU) in 2009, KYPO, CYBERSEC, INJECT



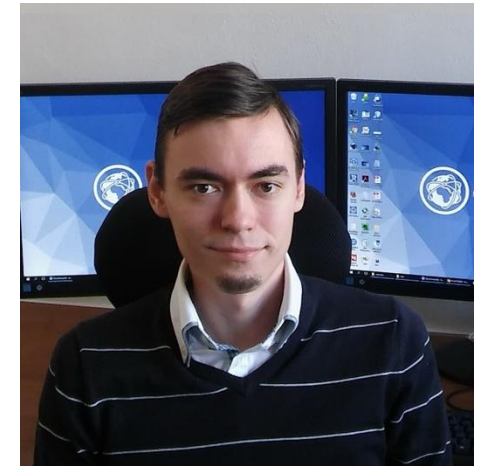
Pavel Čeleda

15+ years of cybersecurity experience CSIRT-MU, Flowmon, KYPO, CYBERSEC, INJECT



Martin Laštovička

current head of CSIRT-MU Security Operations



Goal of this course

- To introduce the role and services of a **Computer Security Incident Response Team (CSIRT)** in an organization.
- To cover specific knowledge and skills required for the work role of Incident Response ([US NIST](#), [EU ENISA](#)), **responsible for investigating, analyzing, and responding to network cybersecurity incidents.**
- A core course of the [Cybersecurity](#) bachelor's degree programme.

Incident Response – Tasks

About **30 tasks** defined by the NIST NICE framework.

Selected tasks:

- T1250: Perform cyber defense incident triage
- T1252: Determine the scope, urgency, and impact of cyber defense incidents
- T1109: Resolve cyber defense incidents
- T0510: Coordinate incident response functions
- T1315: Track cyber defense incidents from initial detection through final resolution
- T1333: Communicate incident findings to appropriate constituencies
- T1372: Advise law enforcement personnel as technical expert

Target audience of this course

- Students of **Cybersecurity** bachelor's degree programme
 - Recommended to study in the **3rd semester**, along with PB177 Cyber Attacks
- Students of **Software Systems and Services Management (N-RSSS) – Cybersecurity Management**
 - One of the compulsory elective courses
- Students who would like to learn how a cybersecurity team works within an organization and with external parties
- Students with **elementary** knowledge and skills from IT (cyber) security, development, and operations

Topics not covered in this course

- Advanced topics from **networks and computer systems** are **NOT** covered in this course
- This course is on **CSIRT services**, such as **incident handling**.
- Sister course on cyber attacks: PB177 Cyber Attacks
- Advanced/specialized courses:
 - PA211 Cybersecurity Operations
 - PV297 Cybersecurity Training
 - PV280 Network Forensics
 - PV300 Lab Project – CYBERSEC
 - PA232 Privacy and Anonymity Technologies

Added value of this course

- Prepared and updated in cooperation with **a real, operational, and certified team CSIRT-MU** and its long-time experience
- Features examples and exercises based on **real cases and incidents** (anonymized to protect privacy)
- Acquired knowledge and skills **directly applicable in practice**

Course format

- Talks by instructors, pair/group discussions, and activities.
- Homework assignments.
- Tabletop exercises.

- For some tasks, you will need a phone/tablet/laptop with a web browser.
- Ask questions during the class directly or using an online tool (see further).
- Taking part in classes is strongly recommended.
- The activities and discussions can hardly be reproduced at home.
- Taught in Czech, course materials will be provided primarily in English.

Course schedule

Week	Date	Topic
1	16/09	Course organization and motivation
2	23/09	Incident handling
3	30/09	Incident handling – case studies
4	07/10	Vulnerability management
5	14/10	<i>no class this week</i>
6	21/10	Situational awareness
7	28/10	<i>public holiday</i>
8	04/11	Tabletop exercise 0
9	11/11	Security advisories
10	18/11	Knowledge transfer
11	25/11	Security policies
12	02/12	Tabletop exercise 1
13	09/12	Tabletop exercise 2
14	16/12	Tabletop exercise 3

Learning knowledge and skills of an incident responder

Week 2–6

Practicing incident response

Week 8

Using the knowledge and skills in team cybersecurity exercises

Week 12–14 (“colloquium” – “k”)

Real-time questions during class – Claper

- You can use Claper for asking questions during the classes.
- We will answer your questions at the end of the class.
- Let's try it now:
Go to <https://claper.fi.muni.cz/e/pv210>
or <https://claper.fi.muni.cz> and type event code **pv210**.



Homework assignments

- 3 individual assignments (HWs)
- HW 1: September 23 (next week) – October 14
- HW 2: November 11 – November 25
- HW 3: November 25 – December 9

Tabletop exercises (TTX)

- Will provide you **unguided experience of solving a common type of security incident involving various parties.**
- Designed for **teams of 3 students** working together as **incident handlers.**
- Team members **receive reports as they would in reality.**
- Your task will be to:
 - **discuss how incident handlers could react,**
 - **suggest some actions** if needed, and
 - **react to the report.**

Grading

Pass/Fail “colloquium” mark (“P” or “N”) based on the following minimal requirements:

- 10 out of 15 points (67%) from homework assignments – no resubmissions.
- Completing important steps in incident handling and producing documents of satisfactory quality in 3 tabletop exercises at the end of the semester.

Will be specified later.

Course organization



Let's start!

Have you ever been hit by cybersecurity attack?

- Discuss in pairs your experience with cybersecurity incidents.
- Make pairs.
- Introduce yourselves.
- Tell your peer what happened.
- What did you do?
- What would you recommend to avoid this incident?
- Listen what happened to your peer.

- Here is my story: *A few years ago, someone misused my ...*

Have you ever been hit by cybersecurity attack?

- If you are done, you can check whether your e-mail, phone number, password and other credentials have been compromised at <https://haveibeenpwned.com/>
- If you still have some time, check your relatives.

Have you been pwned?

- Do you have set notification for new breaches at <https://haveibeenpwned.com/>?
- Do you use two factor authentication (2FA)?
 - For what services?
- Do you use any password manager?
 - Which?

Incident Handling Demonstration

- Let's see one of the thousands of incidents resolved by an operational cybersecurity response team of our university (CSIRT-MU).
- This is a rather simple incident; a more complex incident will be presented next week.

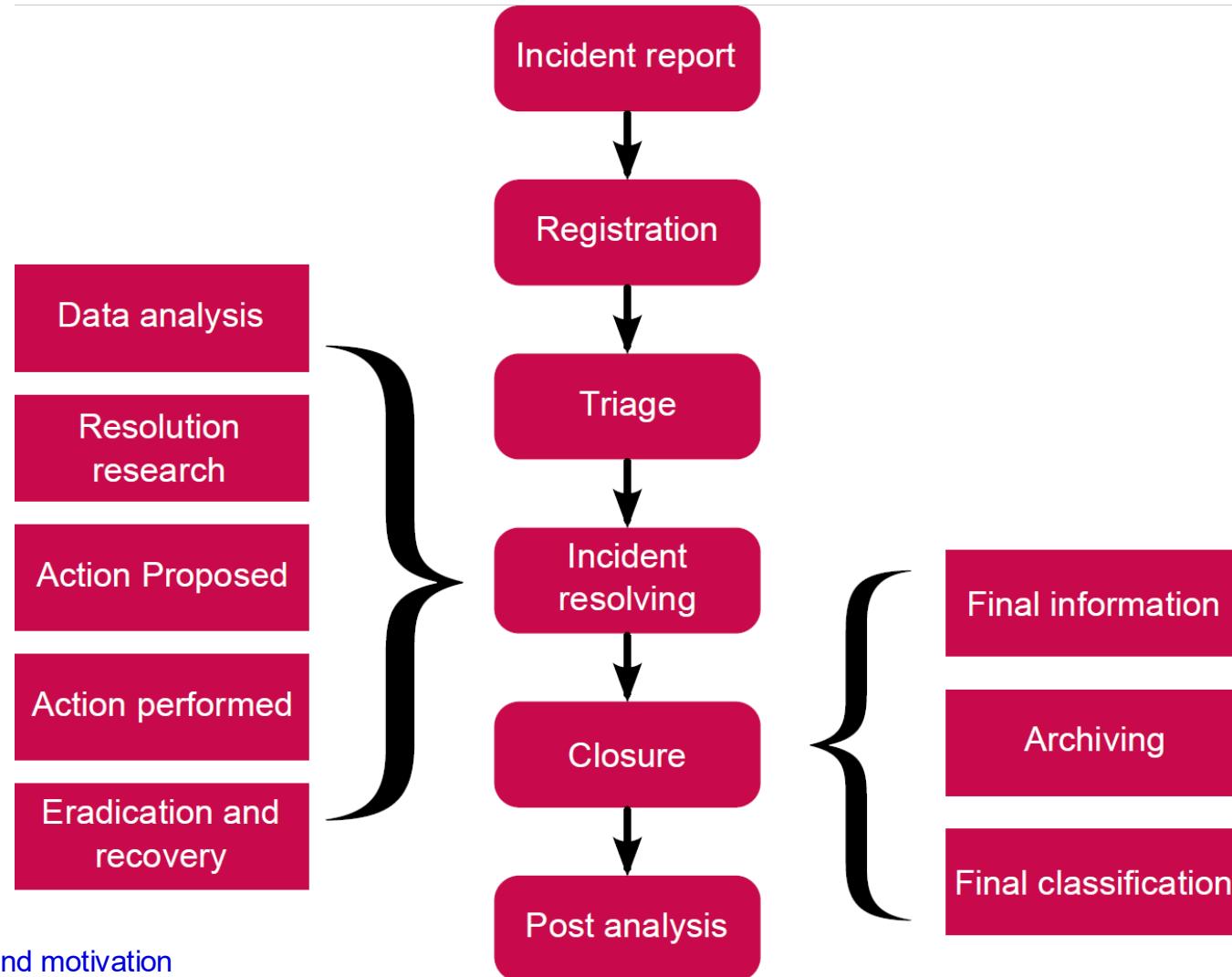
M U N I

Incident Handling Demonstration



M U N I
C S I R T - M U

Incident Handling Phases



Incident Report

Incident Report

- DDoS attack against Czech e-shop `www.kniha<redacted>.cz`.
- Incident responded by their hosting `www.server<redacted>.cz`.
- They identified attack sources in CZ and reported to abuse contact for the IPs

```
~$ whois -b 147.251.163.176
% This is the RIPE Database query service.
% The objects are in RPSL format.
%
% The RIPE Database is subject to Terms and Conditions.
% See https://docs.db.ripe.net/terms-conditions.html

inetnum:          147.251.0.0 - 147.251.255.255
abuse-mailbox:    abuse@muni.cz

% This query was served by the RIPE Database Query Service version 1.120 (SHETLAND)
```

Incident Report – Mail text

Dobrý den,

obracím se na Vás s žádostí o pomoc v situaci, kdy na jeden zákaznický web byl dnes veden DDOS útok.

Do této konverzace jsem Vás přidal z důvodu, že útok šel i z Vaší sítě. Zároveň se omlouvám všem sítím, které měly jen v logu jen jednu adresu, ale naopak tam čekám, že budou akčnější a třeba poskytnou nějaký zajímavý hint.

Parametry útoku:

- L7 HTTPs flood
- URL adresa: <https://www.kniha<redacted>.cz/shop/default?do=setfavourite&oid=335800&page=495>
- Začátek: 13.02.2026 15:18
- Konec: 13.02.2026 15:35

Zajímavé na tomto útoku je převážně fakt, že do něj bylo zapojené velké množství českých IP adres. Domnívám se tedy, že zde existuje botnet, za kterým stojí naši spoluobčané. Nejspíš k tomu využívají nějakou aplikaci/plugin, kterou si uživatelé k sobě v dobré víře nainstalovali.

Jeden takový případ jsme už v minulosti řešili (a i přes nahlášení CSIRT týmu stále vesele nejspíš běží):

<https://www.server<redacted>.cz/blog/ddos-http-flood/>

Bohužel tentokrát jsem nenašel žádné vodítko, kterého se můžu chytit.

V příloze přikládám část access logu z dnešního incidentu pro další možnou další analýzu.

Jako možného pomocníka při debugu vidím existenci EUI-64 IPv6 adres v access logu, pomocí kterých by mohlo být možné identifikovat přesně konkrétní zařízení v síti.

Časové pásmo jak v logu, tak v tomto textu je Praha.

Předem děkuji za reakci a přeji hezký den.

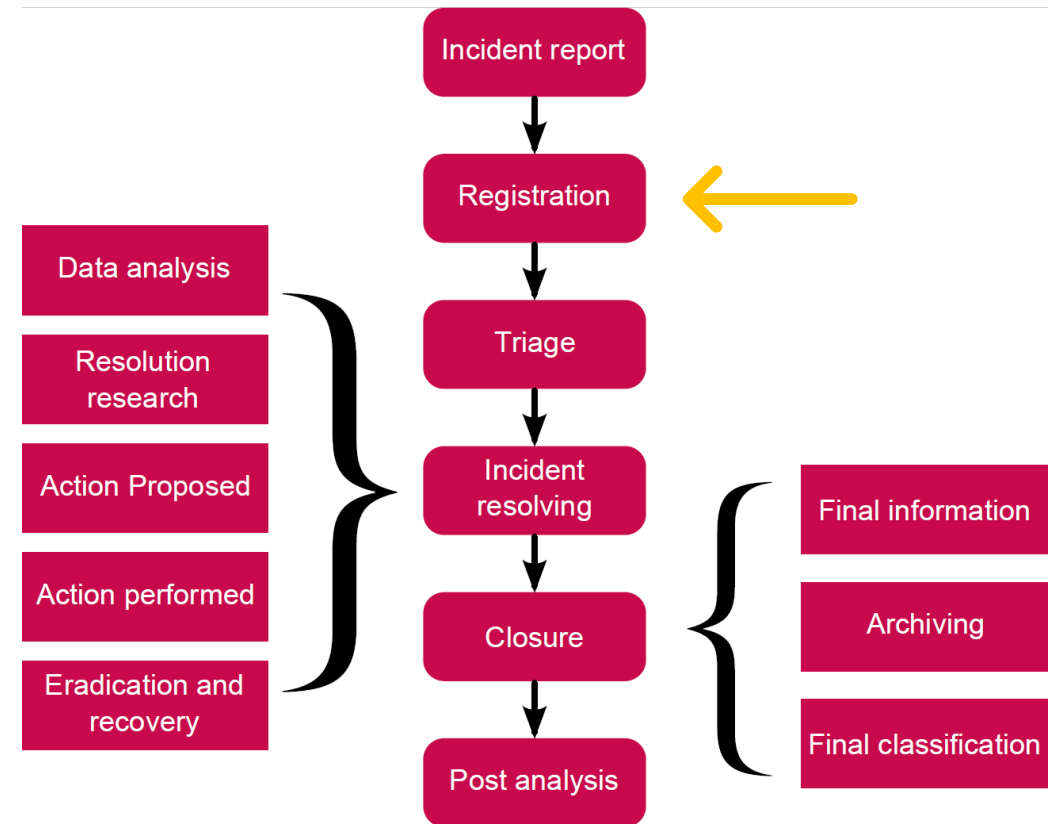
Incident Report – mail attachment

Web logs from the targeted server:

```
$ grep "147.251." kniha<redacted>.cz.ddos.log
```

```
147.251.163.176 - - [13/Feb/2026:15:22:11 +0100] "GET /shop/default?do=setfavourite&oid=335800&page=495 HTTP/2.0" 302 118 "https://kniha<redacted>.cz/"  
"Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/113.0.0.0 Safari/537.36 OPR/99.0.0.0"  
147.251.163.176 - - [13/Feb/2026:15:23:03 +0100] "GET /shop/default?do=setfavourite&oid=335800&page=495 HTTP/2.0" 499 0 "https://kniha<redacted>.cz/" "Mozilla/5.0  
(Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/123.0.0.0 Safari/537.36"  
147.251.163.176 - - [13/Feb/2026:15:24:09 +0100] "GET /shop/default?do=setfavourite&oid=335800&page=495 HTTP/1.1" 403 118 "https://kniha<redacted>.cz/"  
"Mozilla/5.0 (X11; Ubuntu; Linux x86_64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Opera/69.0.0.0 Safari/537.36"  
147.251.163.176 - - [13/Feb/2026:15:24:28 +0100] "GET /shop/default?do=setfavourite&oid=335800&page=495 HTTP/2.0" 403 169 "https://kniha<redacted>.cz/"  
"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.0.0 Safari/537.36 Edg/112.0.1722.84"  
147.251.163.176 - - [13/Feb/2026:15:24:57 +0100] "GET /shop/default?do=setfavourite&oid=335800&page=495 HTTP/2.0" 403 169 "https://kniha<redacted>.cz/"  
"Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.0.0 Safari/537.36 Edg/125.0.0.0"  
147.251.163.176 - - [13/Feb/2026:15:25:13 +0100] "GET /shop/default?do=setfavourite&oid=335800&page=495 HTTP/2.0" 403 169 "https://kniha<redacted>.cz/"  
"Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/117.0.0.0 Safari/537.36 Edg/117.0.0.0"  
147.251.163.176 - - [13/Feb/2026:15:25:47 +0100] "GET /shop/default?do=setfavourite&oid=335800&page=495 HTTP/2.0" 403 169 "https://kniha<redacted>.cz/"  
"Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.0.0 Safari/537.36 OPR/113.0.0.0"  
147.251.163.176 - - [13/Feb/2026:15:26:04 +0100] "GET /shop/default?do=setfavourite&oid=335800&page=495 HTTP/2.0" 403 169 "https://kniha<redacted>.cz/"  
"Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/117.0.0.0 Safari/537.36 OPR/91.0.0.0"  
147.251.163.176 - - [13/Feb/2026:15:26:40 +0100] "GET /shop/default?do=setfavourite&oid=335800&page=495 HTTP/2.0" 403 169 "https://kniha<redacted>.cz/"  
"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/109.0.0.0 Safari/537.36"  
147.251.163.176 - - [13/Feb/2026:15:26:58 +0100] "GET /shop/default?do=setfavourite&oid=335800&page=495 HTTP/2.0" 403 107 "https://kniha<redacted>.cz/"  
"Mozilla/5.0 (X11; Ubuntu; Linux x86_64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Opera/67.0.0.0 Safari/537.36"
```

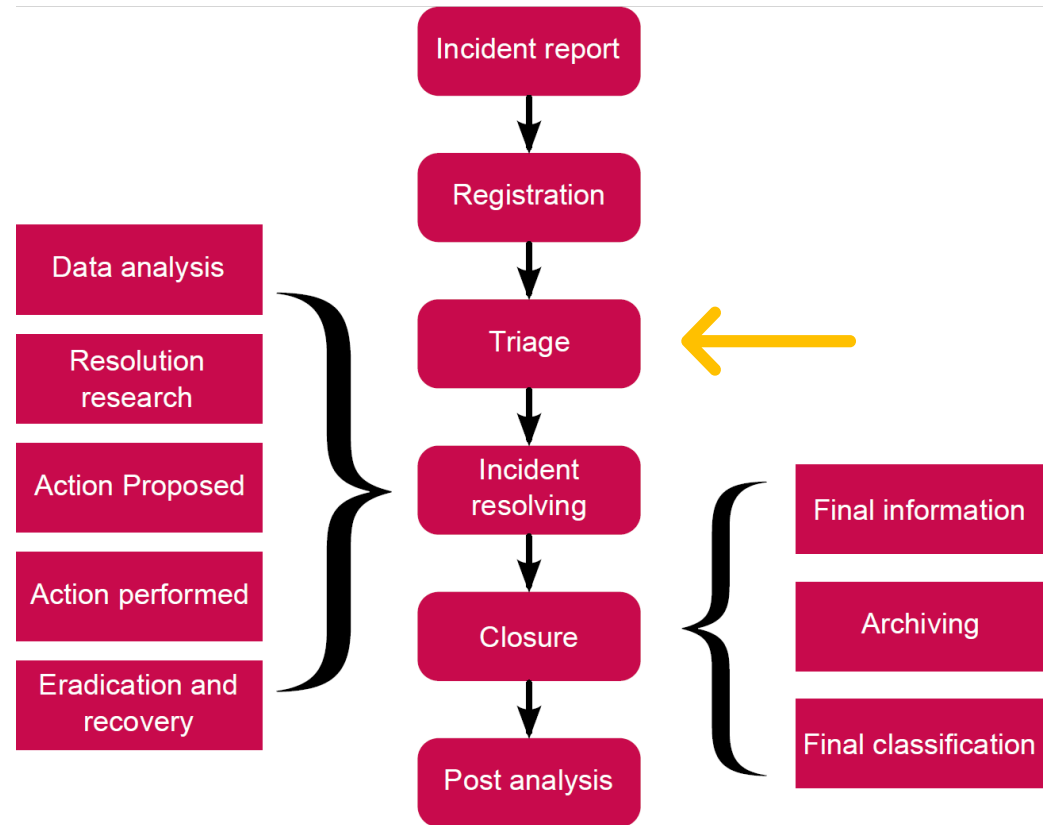
Incident Registration



Incident Registration

- Incoming reports are automatically inserted into Request Tracker
- Identification number was assigned
 - [CSIRT-MU #2614966]

Incident Triage



Incident Triage

1. Incident verification

- Check **network flow records** and try to find communication corresponding to the report
- Verify that it **is indeed a problem**

2. Incident initial classification

- „**Availability - Distributed Denial of Service**“ **category** – could be misconfiguration, hacked machine, compromised account, ...

3. Incident Priority

- **Low** – user devices in Eduroam network produced anomalous traffic

4. Incident assignment

- **One incident handler** is enough – in this case, Martin Kovařík

Incident Triage – Verification in flows (logs)

Q Advanced analysis 2026-02-13 15:20 - 2026-02-13 15:30

STATISTICS LIST OF FLOWS

Limit to 10000

Aggregate

Click to add items

Source IPv4 mask 24

Destination IPv4 mask 24

☒ Sort by start time of flows

☐ Use sampling *i*

☒ Use selected channels ☐ Use all channels in the profile

Output extended-http-d ... + CREATE NEW OUTPUT

☐ Use IP-index *i*

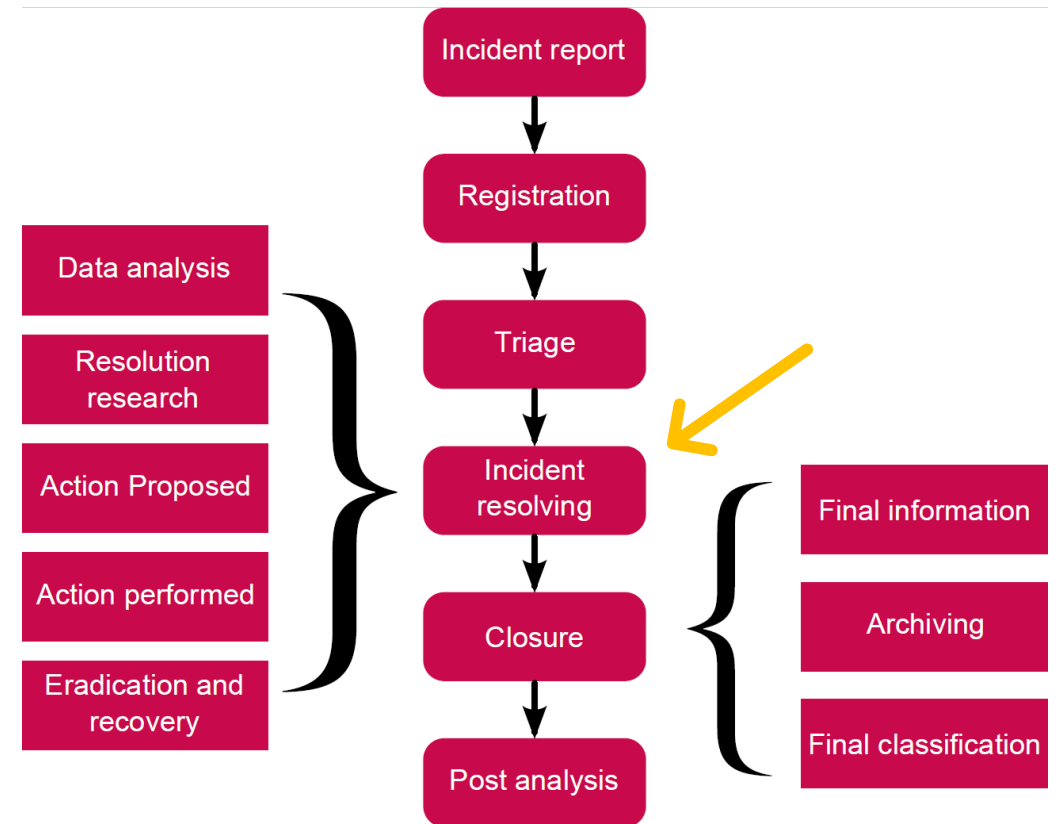
▼ FILTER

ip 147.251.163.176 and hhost "kniha[REDACTED].cz"

Incident Triage – Verification in flows II

START TIME – FIRST SEEN	DURATION	PROTOCOL	SOURCE IP ADDRESS	SOURCE PORT	DESTINATION IP ADDRESS	DESTINATION PORT	TCP FLAGS	PACKETS	BYTES	HOSTNAME
2026-02-13 15:21:56.515	30.132 s	TCP	 147.251.163.176	49737	 220.37	443	AP.SF	42	4.36 KiB	kniha .cz
2026-02-13 15:22:34.741	29.234 s	TCP	 147.251.163.176	49758	 220.37	443	AP.SF	12	1.86 KiB	kniha .cz
2026-02-13 15:24:06.565	2.964 s	TCP	 147.251.163.176	49796	 220.37	443	AP.SF	11	1.53 KiB	kniha .cz
2026-02-13 15:24:23.107	5.353 s	TCP	 147.251.163.176	49813	 220.37	443	AP.SF	16	2.02 KiB	kniha .cz
2026-02-13 15:24:53.757	3.669 s	TCP	 147.251.163.176	49828	 220.37	443	AP.SF	13	1.88 KiB	kniha .cz
2026-02-13 15:25:10.281	3.259 s	TCP	 147.251.163.176	49836	 220.37	443	AP.SF	14	1.88 KiB	kniha .cz
2026-02-13 15:25:45.475	2.09 s	TCP	 147.251.163.176	49858	 220.37	443	AP.SF	13	1.88 KiB	kniha .cz
2026-02-13 15:26:03.512	1.717 s	TCP	 147.251.163.176	49862	 220.37	443	AP.SF	13	1.82 KiB	kniha .cz
2026-02-13 15:26:39.861	0.71 s	TCP	 147.251.163.176	49883	 220.37	443	AP.SF	12	1.8 KiB	kniha .cz
2026-02-13 15:26:57.502	1.169 s	TCP	 147.251.163.176	49890	 220.37	443	AP.SF	12	1.6 KiB	kniha .cz
2026-02-13 15:27:43.327	0.701 s	TCP	 147.251.163.176	49904	 220.37	443	AP.SF	12	1.8 KiB	kniha .cz

Incident Resolution



Incident Resolution – Data Analysis

- In total, 4 machines in Eduroam participated in the DDoS (sending requests to the web).
- A part of the attack was IPv6-only.
- Consider NAT usage – external report uses post-NAT public IPs, to identify users pre-NAT internal IPs are needed.

START TIME – FIRST SEEN	DURATION	PROTOCOL	SOURCE IP ADDRESS	SOURCE PORT	DESTINATION IP ADDRESS	DESTINATION PORT	TCP FLAGS	PACKETS	BYTES	HOSTNAME
2026-02-13 15:19:20.893	26.548 s	TCP	 2001:718:801:900:19c::a	52724	 [REDACTED]:d::2	443	AP.SF	12	2.24 KiB	kniha [REDACTED].cz
2026-02-13 15:20:24.727	25.667 s	TCP	 2001:718:801:900:19c::a	52758	 [REDACTED]:d::2	443	AP.SF	13	2.11 KiB	kniha [REDACTED].cz
2026-02-13 15:21:07.788	25.531 s	TCP	 2001:718:801:900:19c::a	52787	 [REDACTED]:d::2	443	AP.SF	13	2.12 KiB	kniha [REDACTED].cz
2026-02-13 15:21:37.016	0.074 s	TCP	 2001:718:801:900:19c::a	52806	 [REDACTED]:d::2	443	AP.SF	5	825 B	kniha [REDACTED].cz
2026-02-13 15:21:55.382	25.041 s	TCP	 2001:718:801:900:19c::a	52823	 [REDACTED]:d::2	443	AP.SF	15	2.32 KiB	kniha [REDACTED].cz

Incident Resolution – Resolution research

- Why would students coordinate to attack an e-shop?
 - Malware? Botnet?
- Analysis of their traffic to find signs of compromise
 - Communication with proxyware application servers
 - Users installed them to earn money, but they can be used for attacks
- Request users to uninstall the apps

Action Proposed – Mail to users

Greetings,

Team CSIRT-MU has detected participation in a DDoS attack originating from a device using IP address 100.64.8.223, which at the time of detection 2026-02-13 15:32:33 +0100 was assigned to you - UČO <redacted>. Based on traffic analysis, we concluded that the communication originated through an installed Honeygain/Repocket application categorized as proxyware.

This application shares a portion of the user's internet bandwidth and has historically been associated with abuse by threat actors and the downloading of additional malware [1]. Such proxy services may be misused for illegal activities with potential legal consequences, including conducting attacks, as was the case here.

We kindly request that you remove the Honeygain/Repocket application and scan the device using up-to-date antivirus software.

Please inform us within 5 business days about the steps you are taking to resolve this incident.

Best regards,

Martin Kovařík

[1] <https://blog.talosintelligence.com/proxyware-abuse/>

Incident Resolution – Action performed, Eradication and Recovery – I

Sometimes easy, but some users needed additional assistance.

 St 18.úno.2026 17:10:06 [redacted]@mail.muni.cz> - Požadavek vytvořen
Předmět: Re: Network attack originating from your device
Od: [redacted]@mail.muni.cz>
Datum: Wed, 18 Feb 2026 17:09:54 +0100
Komu: csirt@muni.cz

To whom it may concern,
I apologise for the inconvenience. My device was previously from another member of my family and I had not realised the existence of the app.
I am removing it and scanning the device with my McAfee antivirus.

Thank you for the help.

Kind regards,
[redacted]

Incident Resolution – Action performed, Eradication and Recovery – II

 St 18.úno.2026 17:11:26 [REDACTED]@mail.muni.cz> - Korespondence zaznamenána
Komu: csirt@muni.cz
Datum: Wed, 18 Feb 2026 17:11:03 +0100
Předmět: Re: [CSIRT-MU #2624224] Network attack originating from your device
Ods: [REDACTED]@mail.muni.cz>

Hello, dear Martin Kovařík, thank you for informing me about this, and about this, I would like to ask you a question: can you help me with removing this program completely so that there are no further risks of returning this malware?

Incident Resolution – Action performed, Eradication and Recovery – III

 Po 23.úno.2026 15:14:38 [redacted] mail.muni.cz> - Korespondence zaznamenána
Od: [redacted]@mail.muni.cz>
Předmět: Re: [CSIRT-MU #2624226] Sítový útok pocházející z Vašeho zařízení
Datum: Mon, 23 Feb 2026 15:13:06 +0100
Komu: csirt@muni.cz

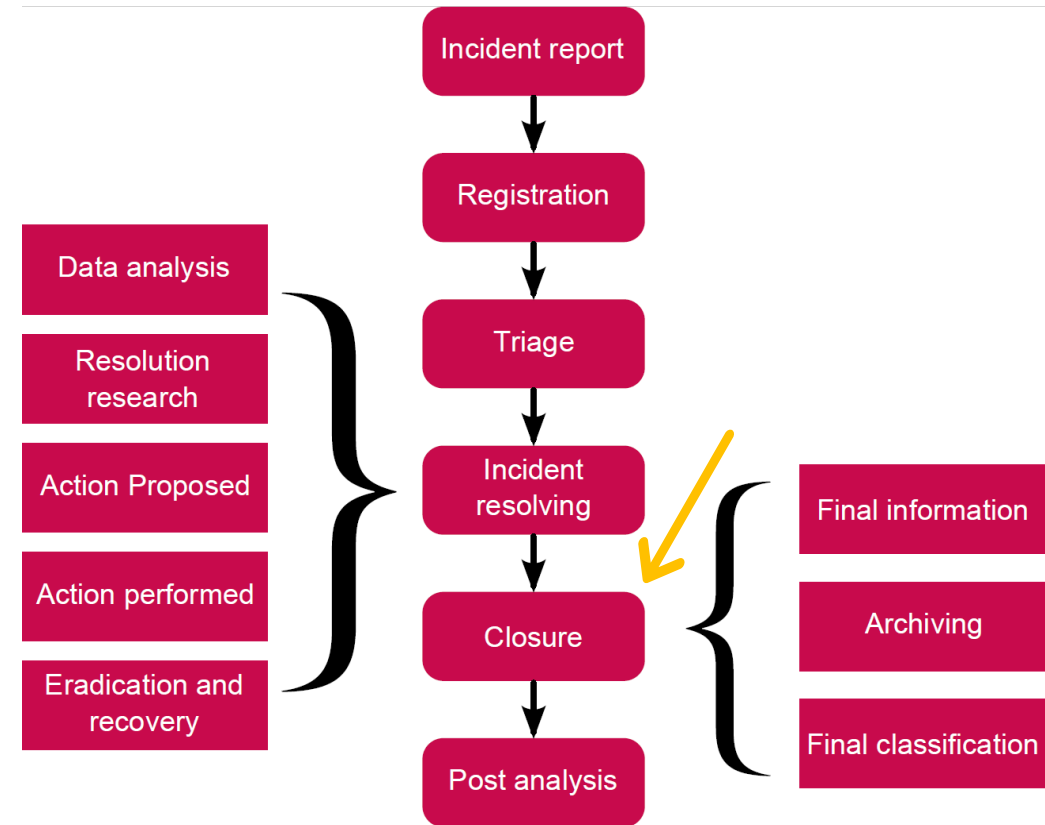
Dobrý den,

děkuji za upozornění. Aplikaci Honeygain jsem ze zařízení odinstaloval a zařízení jsem zkontroloval antivirovým softwarem.

S pozdravem

[redacted]
UČO [redacted]

Incident Closure



Incident Closure

1. Final information

- Information about incident, responsible people, timestamps (all done by Request Tracker)
- Summary of the incident:

Dne 13. 2. nás kontaktovali správci stránek Kniha<redacted> (kniha<redacted>.cz) s informací, že na ně byl vedený DDoS útok formou záplavy HTTP požadavků, do kterého byly zapojeny také adresy z MU. Dle přiložených logů jsme zapojení adres MU potvrdili a provedli analýzu komunikace těchto zařízení.

Celkem se jednalo o 4 uživatele, kteří měli ve svých zařízeních nainstalované proxyware aplikace Honeygain nebo Repocket. Tyto aplikace slibují uživatelům pasivní příjem a vyplácí odměny za sdílení části jejich internetového připojení k dalším aktivitám. Zařízení tak funguje jako proxy, přes kterou je směrována blíže nespecifikovaná komunikace. Tato komunikace může využívat zařízení zákazníků např. pro SEO optimalizaci z jejich adres nebo, jako v tomto případě, k nelegálním aktivitám pro DDoS útoky, případně distribuci malware.

Incident Closure

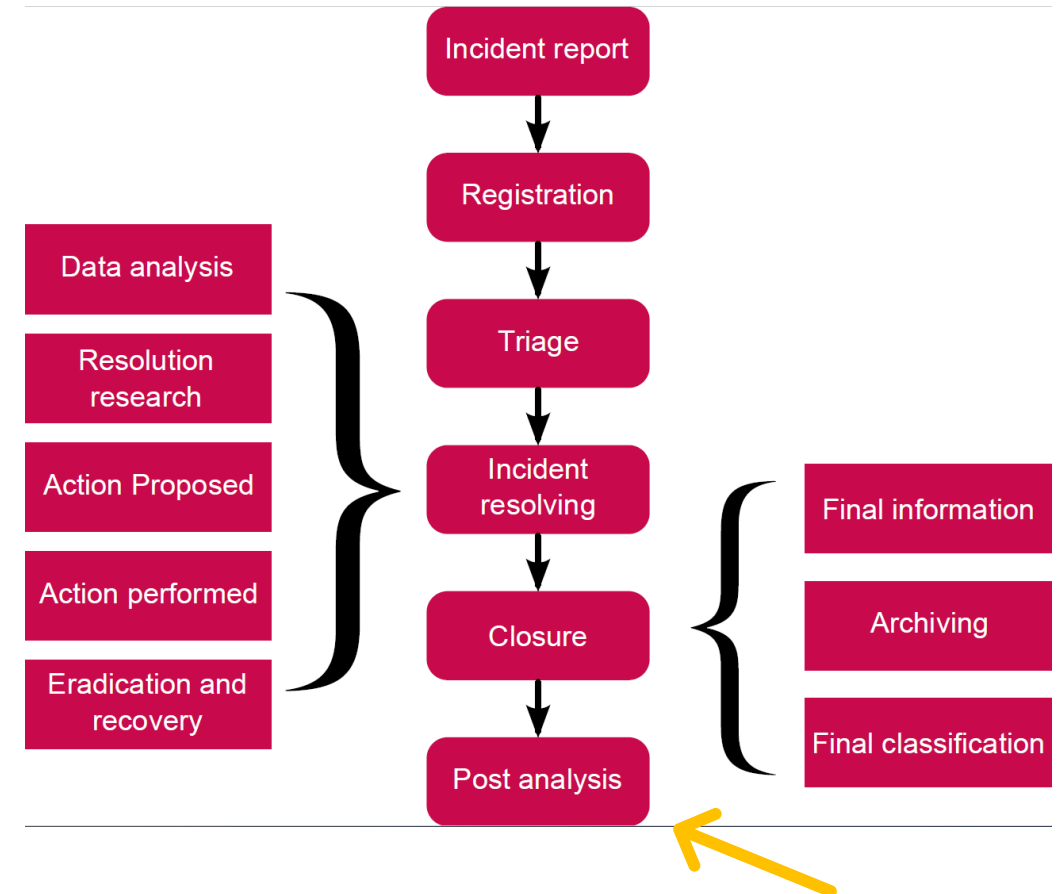
2. Final classification

- „*Availability - Distributed Denial of Service*“ for the original report
- „*Intrusions – System Compromise*“ for tickets with users

3. Archiving

- Done automatically by Request Tracker

Incident Post Analysis



Incident Post Analysis

Lessons learned from incident and recommendations

- New type of DDoS where users „infected“ their devices willingly
- **Explicit ban** on proxyware usage (it was already against MU Directive No. 10/2017)
- A **warning** for all users was issued
<https://csirt.muni.cz/en/varovani/warning-the-use-of-proxyware-applications-is-risky-and-prohibited>
- **New detection method** was written to discover all users with proxyware applications

Warning: the use of proxyware applications is risky and prohibited

Masaryk University's cybersecurity team warns against installing and using proxyware applications. At first glance, they may seem appealing, but in reality they pose a security risk, as they are actively abused for cyberattacks.



26 FEB 2026 | WARNINGS

What do you, as a user, need to know?

The use of proxyware applications is prohibited on the MU network because they are associated with security and legal risks. We are issuing this warning because we have detected several devices on the MU network being involved in DDoS attacks against organizations in the Czech Republic.

Proxyware applications (such as Honeygain or Repocket) “rent out” part of your internet connection to a third party in exchange for compensation. Once installed, they allow unknown individuals to use your device, your IP address, and your internet connection — but **you are the one who bears the consequences**. One of these may be the **loss of access to Eduroam and EduVPN services at MU**.

M U N I

The end of demonstration



M U N I
C S I R T - M U

Position of a CSIRT in an organization

When was the first CERT established?

- In 1980s – one hand up
- In 1990s – both hands up
- In 2000s – no hands

Morris worm – 1988

- 23-year-old student Robert T. Morris released a **worm that infected 10% of the internet.**
- The worm did not damage or destroy files, but **caused DoS.**
- **Early internet lacked a fast way to share security alerts and coordinate fixes.**
- DARPA asked the CMU to establish **a computer emergency response team:**
CERT/CC – Computer Emergency Response Team/Coordination Center.
- CERT/CC was **a neutral 3rd party reporting vulnerabilities to vendors** without revealing the identity of the reporter.
- CERT/CC works with competing vendors whose products contain the same vulnerability, **free of conflicts of interest.**

Sources: [FBI](#), [CMU](#)

CSIRTs before mid 2010s

- CERTs/CSIRTs have been there **a long time before cybersecurity started to be regulated** at the national and international levels.
- Organizations operated or hired CSIRTs to respond to security incident reports (at least).
- The **teams formed communities and associations** to seek trusted contacts and make collaboration more efficient when solving future incidents.
Examples: [TF-CSIRT](#) (Europe and neighbours), [FIRST](#) (global)
- Memberships in these bodies were **not obligatory or required by any law**.

CSIRTs and regulations

- CSIRTs serve legal entities.
- Some of these entities provide **essential services such as critical (information) infrastructure**.
- These entities are now required to implement risk management measures, **report significant incidents promptly**, and ensure executive accountability.
- Non-compliance can lead to **high fines** and even **personal liability** for management bodies.

CSIRTs and regulations – Czech Rep.

- The Czech Republic was **one of the first countries with a dedicated act on cybersecurity (2014)**.
- This act defines the role of **NÚKIB** (Národní úřad pro kybernetickou a informační bezpečnost), **Government and National CERT**.
- **NÚKIB** (NCISA in English) is the **central authority for cybersecurity in the Czech Republic**, established to implement and oversee the Cybersecurity Act.
- **GovCERT.CZ** is a specialized team within NÚKIB focused on handling cybersecurity **incidents affecting government institutions and critical infrastructure**.
- **CSIRT.CZ** complements GovCERT.CZ by focusing on the broader internet community, including private sector and citizens.

CSIRTs and regulations – EU

- **NIS Directive** (Directive on Security of Network and Information Systems) is the first EU-wide legislation on cybersecurity, originally adopted in **2016** and updated as **NIS2** in **2022**, with the goal of enhancing the cybersecurity of critical infrastructure and digital services across the EU.
- **ENISA** (European Union Agency for Cybersecurity) supports the implementation of the NIS Directive by providing technical guidance, coordinating the CSIRT network, maintaining cybersecurity registries, and assisting EU Member States in developing national strategies and incident reporting frameworks.
- The **NIS2 directive is implemented in Czech law by a new Act on Cybersecurity**, effective from **November 1st, 2025**.
- Learn more in compulsory courses from the Faculty of Law and the Faculty of Social Studies.

CSIRT Glossary

- **Mission Statement** — What do you do?
 - „A mission statement describes the organizations basic function in society, in terms of the products and services it provides for its constituents. It allows communicating clearly the existence and the function of the CSIRT.“ [2]
- **Constituency** — For whom you do that?
 - „The customer base of a CSIRT.“ [2]
 - „A specific group of people and/or organizations that have access to specific services offered by a CSIRT.“ [1]
- **Sponsorship/Affiliation** — Who pays for that?
 - „The sponsoring organization, which authorizes the actions of the CSIRT.“ [3]

CSIRT-MU Example

– Mission Statement

- The goals of CSIRT-MU are:
 - to create trustworthy central contact point for ICT infrastructure at MU,
 - to prevent, detect and resolve computer security incidents related to the MU ICT infrastructure,
 - to raise IT security awareness among students and staff of MU,
 - to research and develop tools, technologies and procedures to contribute to the state-of-the-art cyber security domain.

– Constituency

- The constituency are students and staff of Masaryk University, Brno, Czech Republic and the Masaryk University network:
 - all IPv4 addresses within range 147.251.0.0/16,
 - all IPv6 addresses within range 2001:718:801::/48,
 - domain muni.cz.

– Sponsorship and/or Affiliation

- CSIRT-MU is part of Institute of Computer Science, Masaryk University.

CSIRTs According to Constituency

- National – the whole country
- Government – public administration, critical infrastructure
- Military – armed forces
- Internet Service Provider – customers
- Vendor – specific product
- Commercial – private organization
- Academic – research and education institutions, such as CSIRT-MU for Masaryk University
- CSIRT as a Service – whoever pays

CSIRTs in the Czech Republic – I

How many CSIRTs operate in the Czech Republic?

CSIRTs in the Czech Republic – II

How many CSIRTs operate in the Czech Republic?

74 as listed in the [Trusted Introducer Team Database](#) as of September 14, 2026

Constituency type:

- Commercial Organisation (37)
- ISP Customer Base (31)
- Service Provider Customer Base (21)
- Research & Education (8)

Authority over Constituency [1]

– Full

- The members of the CSIRT have the authority to undertake any necessary actions or decisions on behalf of their constituency

– Shared

- The members of the CSIRT provide **direct support to their constituents and share in the decision-making process** (i.e., have influence in constituency decisions, but are cannot decide alone)
- *CSIRT-MU ensures coordination of security incident response, actions on local infrastructure (faculties, dormitories, ...) carried out by its administrators*

– None

- The members of the CSIRT have no authority over their constituency

Place in Organization

- Part of system or network administration department
 - A clear mismatch in responsibility, it is destined to fail [1]
- Part of management/legal department
 - Business strategy, risk management, security policies
- Standalone unit
 - Needs to establish good relations to all other units in organization
 - *CSIRT-MU*

Mandate of a CSIRT

- Legal duty
 - CSIRT operation is demanded by law (such as “Zákon o kybernetické bezpečnosti”)
- Internal security directive
 - CSIRT-MU mandate comes from MU Directives No. [9/2017](#) and [10/2017](#)
- Good intentions
 - academic teams, ”geek” ISP, domain name registrars

Level of Support

- Incident response on site

- The CSIRT itself physically analyses the affected systems and conducts the repair and recovery of the systems

- Incident response support

- The CSIRT assists and guides the victims of the attack in recovering from an incident via phone, email, fax, or documentation. This can involve technical assistance in the interpretation of data collected, providing contact information, or relaying guidance on mitigation and recovery strategies
 - E.g. CSIRT-MU helps administrators resolve the security incident

- Incident response coordination

- The CSIRT coordinates the response effort among parties involved in the incident

Business Model

– 8/5

- Typical 40 working hours a week
- Minimal staff requirement for basic service is 4 FTE [2]
- CSIRT-MU business hours are 09:00-17:00 Monday to Friday except for holidays
- What if an incident happens on Friday at 6 PM?

– 24/7

- 168 working hours a week, including night shifts, weekends, holidays
- More than 4x the amount of time to cover with extra payment for special shifts
- Is a faster reaction worth the cost?

CSIRT vs. SOC

CSIRT (Computer Security Incident Response Team)

- Incident resolution
- Incident prevention
 - Vulnerability handling
 - Education
 - Policies
- Can do incident detection
(as SOC)

SOC (Security Operations Centre)

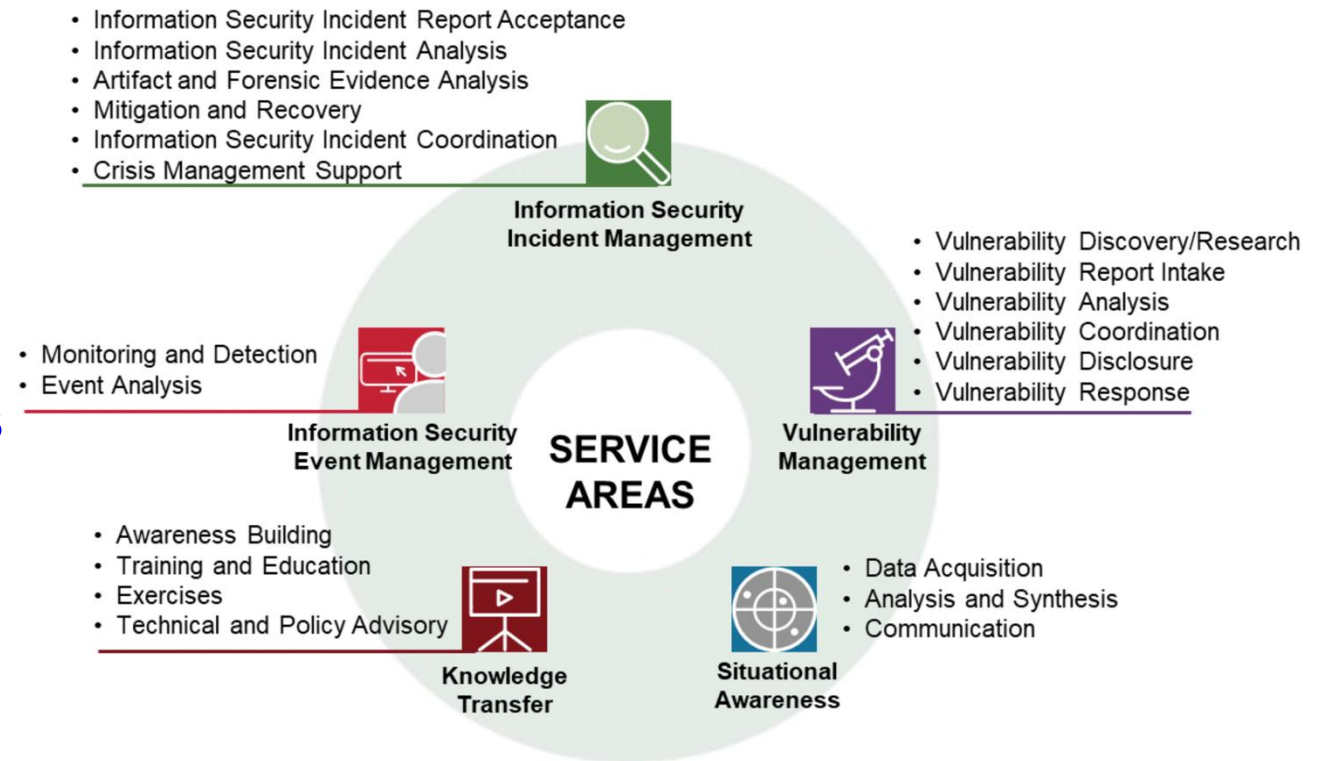
- Threat/incident detection
- Data collection and correlation
- Monitoring (often 24/7)
- Can do incident resolution
(as CSIRT)

Product Security Incident Response Team (PSIRT)

- Focuses on **vulnerability management** in products and services.
- Specialized teams or capabilities that respond within vendor organizations or service providers to handle and resolve vulnerabilities in products or services.
- Learn more about the capabilities of different teams in [Team Types Within the Context of Services Frameworks](#) by FIRST.

CSIRT Services

- No team can provide all services and functions
- Need to define and communicate the provided service subset
- FIRST.org defines **5 Service areas** covering **21 Services** divided into **76 Functions**



CSIRT Services [4]

- Information security **event management**
 - Monitoring and detection
 - Event analyzing
- Information security **incident management**
 - Accepting information security incident reports
 - Analyzing information security incidents
 - Analyzing artefacts and forensic evidence
 - Mitigation and recovery
 - Information security incident coordination
 - Supporting crisis management
- **Situational awareness**
 - Data acquisition
 - Analyze and interpret
 - Communication
- **Vulnerability management**
 - Vulnerability discovery / research
 - Vulnerability report intake
 - Vulnerability analysis
 - Vulnerability coordination
 - Vulnerability disclosure
 - Vulnerability response
- **Knowledge transfer**
 - Awareness building
 - Training and education
 - Exercises
 - Technical and policy advisory

References

1. Molra J West-Brown, Don Stikvoort, Klaus-Peter Kossakowski, Georgia Killcrece, and Robin Ruefle. “Handbook for computer security incident response teams (CSIRTs).” In: *Software Engineering Institute Technical Report CMU/SEI-2003-HB-002* (2003), p. 201. URL: https://resources.sei.cmu.edu/asset_files/handbook/2003_002_001_14102.pdf
2. Henk Bronk, Marco Thorbruegge, and Mehdi Hakkaja. “A step-by-step approach on how to set up a CSIRT.” Dec. 2006. ENISA. Superseded by How to set up CSIRT and SOC, URL: <https://www.enisa.europa.eu/publications/how-to-set-up-csirt-and-soc>.

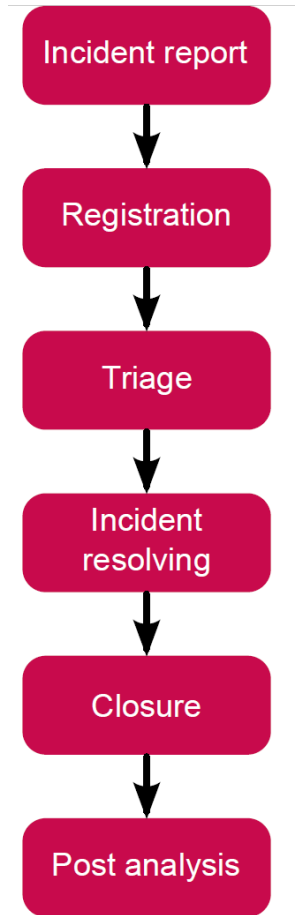
References II

3. Nevil Brownlee and Erik Guttman. “RFC 2350: Expectations for Computer Security Incident Response.” Jun. 1998. URL: <https://tools.ietf.org/html/rfc2350>
4. Vilius Benetis, Olivier Caleff et al. “Computer Security Incident Response Team (CSIRT) Services Framework.” Version 2.1 Nov. 2019. URL: https://www.first.org/standards/frameworks/csirts/csirt_services_framework_v2.1

Class activity: What can a CSIRT do?

What can a security team do when data were leaked?

- Imagine you run a cybersecurity team of Masaryk University (CSIRT-MU).
- You have just learned that names, e-mail addresses, UČO, and primary passwords to Information System of some students and staff were posted at the public paste site (such as PasteBin).
- How would you react as a security team?



Possible actions

Immediate:

- Verify whether the leaked data are true
- Contact all affected users and notify them about the leak
- Reset all leaked passwords
- Ask a paste site for removing the leaked data
- Ask administrators of IS MU to search for anomalous accesses
- Report the incident to the top management
- Publish a press release, blog post, tweet, ... for the media and the general public

Possible actions II

Preventive:

- Sign up for notifications about the data breaches (such as [Czech GovCERT for domains from the state sector from Have I Been Pwned](#))
- Run a penetration test to reveal vulnerabilities of IS MU
- Prepare and test an incident response plan for a data breach

Possible actions III

Required by law:

- IS MU is used for delivering a regulated service according to Act on Cybersecurity, CSIRT is obliged to report this incident
- IS MU processes personal data of users, leaking these data constitutes an incident according to General Data Protection Regulation (GDPR), an organization is obliged to report the breach to the supervisory authority, CSIRT should interact with the Data Protection Officer

Next week

- You will work with a document in a class activity.
- Bring your own laptop if you can. You will appreciate a bigger display than on your phone.

Other announcements – Kybersoutěž

- A new year of Czech national cybersecurity competition has been started.
- Open for primary, high school and **university students** aged 9–**24**.
- Register at <https://www.kybersoutez.cz> now.



Other announcements – MUNI CTF Meetup

Hack with [CSIRT-MU](#) and your peers at monthly meetups.

When: Friday, September 18, 12:00–20:00

Where: Meeting Room 15.21 in **Šumavská Tower A** (15th floor)

What do you need: Kali Linux VM and a free account on [HackTheBox](#)

For more information how to get there contact Jiří Rája at raja@ics.muni.cz.

Questions, answers, and feedback in Claper

- You can use Claper for asking questions during the classes.
- We will answer your questions at the end of the class.
- Go to:
<https://claper.fi.muni.cz/e/pv210>
- **Please provide us with feedback:**
How can today's class be improved?

